



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



npm Supply-Chain Threat Landscape and Red Hat Cloud Services Package Campaign Report

Threat Report

Classification	TLP:CLEAR
Published	2026-06-30
Version	1.0
Author	Lost Boys Cyber
Report Type	Threat Report

TLP:CLEAR | Lost Boys Cyber | npm Supply-Chain Threat Landscape and Red Hat Cloud Services Package Campaign Report - Threat Report

Published: 2026-06-30 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirements
3. Source Review & Confidence
4. Threat Actor / Campaign Overview
5. Tactics, Techniques, and Procedures
6. Infrastructure and Indicators
7. Victimology and Targeting
8. Detection Engineering
 - 8.1. Detection Logic Summary
 - 8.2. Sigma / Detection Rule
 - 8.3. Hunt Query
9. Threat Hunting
 - 9.1. Hunt Hypotheses
 - 9.2. Network Hunt Query
10. Risk Assessment
11. Recommended Actions
12. References

npm Supply-Chain Threat Landscape and Red Hat Cloud Services Package Campaign Report

1. Executive Summary

Unit 42 reported on the npm threat landscape and noted a June 2026 supply-chain attack affecting packages under the @redhat-cloud-services namespace. Developer workstations and CI systems should treat package provenance as a detection surface, not only a software composition analysis problem.

2. Intelligence Requirements

Requirement	Answer in This Report
What happened?	Public reporting describes npm package compromise activity and mitigation patterns.
Who is affected?	Software engineering teams, CI/CD environments, and organizations consuming npm dependencies.
What should defenders do?	Pin dependencies, audit package provenance, monitor install scripts, and isolate CI secrets.
Confidence	Medium-high based on primary Unit 42 reporting and known npm supply-chain patterns.

3. Source Review & Confidence

Source	Contribution	Confidence
Unit 42 npm threat landscape	Primary analysis of npm attack surface and June campaign	High
npm package scripts documentation	Explains package script execution surface	High
CISA Secure by Design software supply chain guidance	Defender mitigation context	Medium

4. Threat Actor / Campaign Overview

npm compromise gives attackers an asymmetric path: one package update can reach many developer and build environments. The highest-impact controls are token hygiene, package-lock review, install-script restrictions, and outbound monitoring from CI.

5. Tactics, Techniques, and Procedures

Tactic	Technique / Behavior	Defensive Interpretation
Initial Access	Malicious or compromised package dependency	Review package provenance and lockfile changes.
Execution	postinstall/preinstall scripts	Monitor package-manager child processes.
Credential Access	CI secrets and developer tokens	Scope and rotate tokens after suspicious installs.

6. Infrastructure and Indicators

Observable Type	Signal	Notes
Behavior	Source did not publish stable atomic IOCs	Hunt on process, network, identity, and SaaS behaviors.

Hard IOCs are limited where primary sources did not publish stable indicators. Treat behavior, infrastructure class, and telemetry pivots as the primary hunting path until local intelligence enrichment identifies environment-specific indicators.

7. Victimology and Targeting

Targets are downstream users of compromised packages rather than a single named victim.

8. Detection Engineering

8.1. Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
Suspicious script or LOLBin execution	Endpoint process telemetry	Surface initial execution and staging activity
New external connection after lure/app execution	Network telemetry	Identify callback or payload retrieval
Unusual account, mailbox, or SaaS activity	Identity/SaaS audit logs	Detect credential abuse and persistence

8.2. Sigma / Detection Rule

<pre> title: Suspicious Script and Remote Tool Activity - npm-supply-chain-threat-landscape-redhat status: experimental logsource: product: windows category: process_creation detection: selection_tools: Image endswith: - '\powershell.exe' - '\wscript.exe' - '\cscript.exe' - '\mshta.exe' - '\rundll32.exe' selection_suspicious: CommandLine contains: - 'http' - 'download' - 'EncodedCommand' - 'Invoke-Expression' condition: selection_tools and selection_suspicious level: high </pre>

8.3. Hunt Query

<pre> DeviceProcessEvents where Timestamp > ago(14d) where FileName in~ ("powershell.exe", "wscript.exe", "cscript.exe", "mshta.exe", "rundll32.exe", "node.exe", "osascript") where ProcessCommandLine has_any ("http", "download", "EncodedCommand", "Invoke-Expression", "curl", "wget") project Timestamp, DeviceName, AccountName, FileName, ProcessCommandLine, InitiatingProcessFileName </pre>

9. Threat Hunting

9.1. Hunt Hypotheses

Hypothesis	Query Focus
Initial access used lure-driven script, package, or web exploitation behavior.	Correlate suspicious process launches with browser, archive, package-manager, or web-server parents.
Follow-on access used identity or remote-management tooling.	Review new OAuth grants, administrative changes, RMM agents, and rare remote endpoints.

9.2. Network Hunt Query

<pre>DeviceNetworkEvents where Timestamp > ago(14d) where InitiatingProcessFileName has_any ("powershell.exe", "node.exe", "python.exe", "osascript", "curl", "wget") summarize Connections=count(), RemoteUrls=make_set(RemoteUrl, 20) by DeviceName, InitiatingProcessFileName, RemoteIP order by Connections desc</pre>

10. Risk Assessment

Risk Area	Assessment	Rationale
Initial Access	Elevated	Recent reporting indicates active or plausible attacker interest.
Credential Exposure	Medium-High	Many campaigns convert endpoint access into identity abuse.
Operational Disruption	Medium	Impact depends on privilege, sector, and dependency concentration.

11. Recommended Actions

Priority	Owner	Action
High	SOC	Deploy hunts in this report and tune to local telemetry.
High	IT/security engineering	Patch exposed systems, verify EDR coverage, and restrict script interpreters where possible.
Medium	Identity team	Review new privileged accounts, OAuth grants, and risky sign-ins for the lookback period.
Medium	Threat intel	Track source updates for IOCs, exploit details, and sector-specific victimology.

12. References

- [1] Unit 42 npm threat landscape — <https://unit42.paloaltonetworks.com/monitoring-npm-supply-chain-attacks/>
- [2] npm package scripts documentation — <https://docs.npmjs.com/cli/v10/using-npm/scripts>
- [3] CISA Secure by Design software supply chain guidance — <https://www.cisa.gov/securebydesign/software-supply-chain>